



NTNU
Norwegian University of
Science and Technology

Security CTF, penetration testing, bug bounty

Donn Morrison

Department of Computer Science

Outline

Capture the flag

Penetration testing

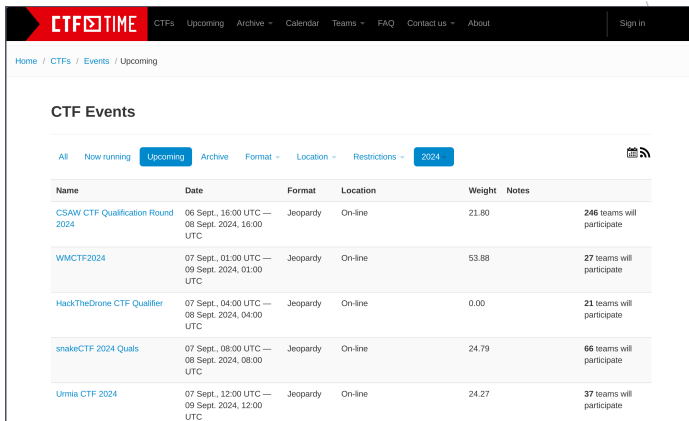
Bug bounty

Experiences with BSc pentest projects

Capture the flag (CTF)

- Use knowledge of cryptography, steganography, binary analysis, reverse engineering, mobile/network security, etc. to find hidden flags
- Useful practice for real world problems
- Contest types:
 - Jeopardy
 - Attack-defense
 - Mixed
- Teams very common

Upcoming CTF events



The screenshot shows the CTFTime website's 'Upcoming' events page for 2024. The page features a navigation bar with links to CTFs, Upcoming, Archive, Calendar, Teams, FAQ, Contact us, and About. A 'Sign in' button is also present. Below the navigation bar, the breadcrumb trail reads 'Home / CTFs / Events / Upcoming'. The main section is titled 'CTF Events' and includes a filter bar with options: All, Now running, Upcoming (selected), Archive, Format, Location, Restrictions, and 2024 (selected). A RSS feed icon is located to the right of the filter bar. The events are listed in a table with columns: Name, Date, Format, Location, Weight, and Notes.

Name	Date	Format	Location	Weight	Notes
CSAW CTF Qualification Round 2024	06 Sept., 16:00 UTC — 08 Sept. 2024, 16:00 UTC	Jeopardy	On-line	21.80	246 teams will participate
WMCTF2024	07 Sept., 01:00 UTC — 09 Sept. 2024, 01:00 UTC	Jeopardy	On-line	53.88	27 teams will participate
HackTheDrone CTF Qualifier	07 Sept., 04:00 UTC — 08 Sept. 2024, 04:00 UTC	Jeopardy	On-line	0.00	21 teams will participate
snakeCTF 2024 Quals	07 Sept., 08:00 UTC — 08 Sept. 2024, 08:00 UTC	Jeopardy	On-line	24.79	66 teams will participate
Urmia CTF 2024	07 Sept., 12:00 UTC — 09 Sept. 2024, 12:00 UTC	Jeopardy	On-line	24.27	37 teams will participate

<https://ctftime.org/event/list/upcoming>

Outline

Capture the flag

Penetration testing

Bug bounty

Experiences with BSc pentest projects

Penetration testing

Red-, blue-, purple-teaming

- Red team: test security by emulating tools and techniques of attackers
- Blue team: internal security team defending against red teams (and real attackers)
- Purple team: integrate blue team tactics with red team threats and vulnerabilities

<https://danielmiessler.com/study/red-blue-purple-teams/>

Methodologies

- MITRE ATT&CK Matrix for Enterprise
- OWASP Testing Guides (WSTG)
- Penetration Testing Execution Standard (PTES)
- PCI Penetration Testing Guide
- Penetration Testing Framework
- Technical Guide to Information Security Testing and Assessment (NIST)
- Open Source Security Testing Methodology Manual

https://owasp.org/www-project-web-security-testing-guide/latest/3-The_OWASP_Testing_Framework/

1-Penetration_Testing_Methodologies

Penetration testing phases generalised

1/2

1. Agreement phase

- What, when, where, how to test
- Don't take down production stuff
- When to stop
- Non-disclosure agreement

2. Planning/recon

- Information gathering
- OSINT

3. Scanning

- Map attack surfaces
- Servers, services, infrastructure
- Version information of services
- Record exploitable vulnerabilities

Penetration testing phases generalised

2/2

4. Gaining access

- Identify targets
- Exploit identified vulnerabilities with aim to gain access

5. Maintaining access

- Persistence
- Live in the system and collect knowledge

6. Evidence collection and report generation

<https://www.greycampus.com/blog/information-security/>

[penetration-testing-step-by-step-guide-stages-methods-and-application](#)

MITRE ATT&CK

ATT&CK Matrix for Enterprise

layout: side ▾

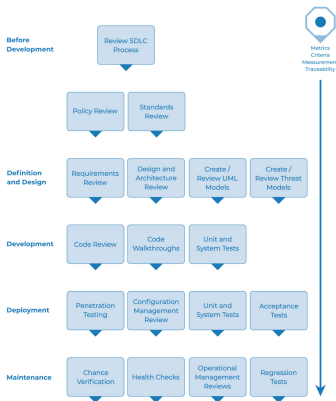
show sub-techniques

hide sub-techniques

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement
10 techniques	7 techniques	9 techniques	13 techniques	19 techniques	13 techniques	42 techniques	17 techniques	30 techniques	9 techniques
Active Scanning (3)	Acquire Infrastructure (7)	Drive-by Compromise	Command and Scripting Interpreter (8)	Account Manipulation (5)	Abuse Elevation Control Mechanism (4)	Abuse Elevation Control Mechanism (4)	Adversary-in-the-Middle (3)	Account Discovery (4)	Exploitation of Remote Services
Gather Victim Host Information (4)	Compromise Accounts (3)	Exploit Public-Facing Application	Container Administration Command	BITS Jobs	Access Token Manipulation (5)	Access Token Manipulation (5)	Brute Force (4)	Application Window Discovery	Internal Spearphishing
Gather Victim Identity Information (3)	Compromise Infrastructure (7)	External Remote Services	Deploy Container	Boot or Logon Autostart Execution (1,4)	Access Token Manipulation (5)	BITS Jobs	Credentials from Password Stores (5)	Browser Bookmark Discovery	Lateral Tool Transfer
Gather Victim Network Information (6)	Develop Capabilities (4)	Hardware Additions	Exploitation for Client Execution	Boot or Logon Initialization Scripts (5)	Boot or Logon Autostart Execution (1,4)	Build Image on Host	Exploitation for Credential Access	Cloud Infrastructure Discovery	Remote Service Session Hijacking (2)
Gather Victim Org Information (4)	Establish Accounts (3)	Phishing (3)	Inter-Process Communication (3)	Browser Extensions	Boot or Logon Initialization Scripts (5)	Debugger Evasion	Forced Authentication	Cloud Service Dashboard	Remote Services (6)
Phishing for Information (3)	Obtain Capabilities (6)	Replication Through Removable Media	Native API	Compromise Client Software Binary	Create or Modify System Process (4)	Deobfuscate/Decode Files or Information	Forge Web Credentials (2)	Cloud Service Discovery	Replication Through Removable Media
Search Closed Sources (2)	Stage Capabilities (6)	Supply Chain Compromise (3)	Scheduled Task/Job (5)	Create Account (3)	Domain Policy Modification (2)	Deploy Container	Input Capture (4)	Cloud Storage Object Discovery	Software Deployment Tools
Search Open Technical Databases (5)		Trusted Relationship	Serverless Execution	Create or Modify System Process (4)	Escape to Host	Direct Volume Access	Modify Authentication Process (7)	Container and Resource Discovery	Taint Shared Content
Search Open Websites/Domains (3)		Valid Accounts (4)	Shared Modules	Event Triggered Execution (16)	Event Triggered Execution (1,8)	Execution Guardrails (1)	Multi-Factor Authentication Interception	Debugger Evasion	
Search Victim-Owned Websites			Software Deployment Tools	System	Exploitation for Privilege	Exploitation for Defense Evasion	File and Directory Permissions	Domain Trust Discovery	
						File and Directory Permissions		File and Directory Discovery	

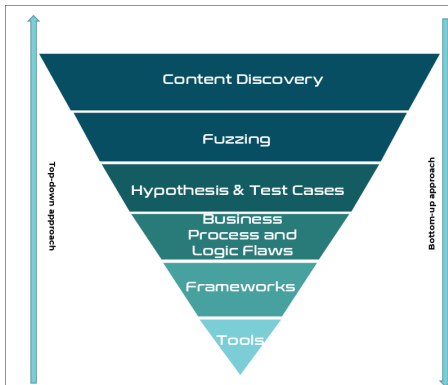
<https://attack.mitre.org/>

OWASP The Web Security Testing Framework



https://owasp.org/www-project-web-security-testing-guide/stable/3-The_OWASP_Testing_Framework/0-The_Web_Security_Testing_Framework

Top-down, bottom-up



Producing High Value Penetration Tests

Reliable and consistent testing is important, and not relying on a single individuals' skills and efforts to complete a penetration test helps ensure the highest levels of standards.



Team Based Effort

Penetration Testing is a team effort, not an individual effort. Utilize a team to maximize the penetration test efforts.



Thoroughly Map Attack Surface

Leave no stone untouched. Many vulnerabilities are found in the "paths least travelled". Fully explore!



Reporting

Document findings, process, discrepancies and hypothesis. It will be useful now and later.



Hypothesis and Knowledge Sharing

A team is stronger. Produce hypothesis to uncover potential attacks across all layers. Strengthen the team knowledge by working as one.

<https://riversecurity.eu/wordpress/wp-content/uploads/2023/02/hackcon-webapps.pdf> (HackCon Oslo 2023)

Pentest: Trondheim Folkebibliotek

Bachelor project-based penetration test of Trondheim Folkebibliotek's public facing network infrastructure.

Details:

- Spring semester 2020
- Followed OWASP methodology
- Attack scope
 - Public computers
 - Wireless access points
 - Web servers
 - Book scanners, etc.

Pentest: Trondheim Folkebibliotek

Results:

- Gained access to information for 3,5 million loaners (probably your information too!)
- Uncovered poor data security data practices
- Uncovered a wide range of XSS and HTTP header injection vulnerabilities in the web platform
- Gained root/persistence on multiple servers via remote code execution
- Outdated software subject to multiple published CVEs
- Uncovered multiple security issues on public computers
- Made national news <https://www.nrk.no/kultur/studenter-avslorte-alvorlig-sikkerhetsfeil-i-biblioteks-15076878>

Such penetration tests help to improve the security of systems that may never have had a critical eye.

Outline

Capture the flag

Penetration testing

Bug bounty

Experiences with BSc pentest projects

Bug bounty

- Hacking for good
- Spare time hobby
- Extra income
- Skills improvement

Bug bounty - getting started

- Create an account on one of the main platforms
 - Bugcrowd
 - Hackerone
 - intigriti.com
- Peruse the public programs, find one you're interested in
 - Choose based on usage familiarity (you already use the service/application)
 - Choose based on technology familiarity (e.g., Tomcat)
- With more experience, you get invited to private programs

Bug bounty - getting started

— Start hacking

- Get familiar with the application
- What is the attack surface? Map as much as possible
- Take notes
- Avoid automation/scanning in the beginning
- Aim for impact
- Stay in scope!

— Write reports

- Summary
- Steps to reproduce
- Impact
- Timeline

Bug bounty - challenges

- Bugs can be hard to find, don't get discouraged
- Then there's the inevitable duplicate
- Then there's disagreements on impact/severity
- Then it can take time before vuln fixed
- Then there's the issue of public disclosure

Outline

Capture the flag

Penetration testing

Bug bounty

Experiences with BSc pentest projects

Recent activity

- Bachelor projects
 - 2020: Trondheim folkebibliotek
 - 2021: NTNU SoC internal projects, Picterus
 - 2022: Asus wireless router
 - 2023: Inspira, Reolink IP cameras
 - 2024: Fuzzing Reolink IP cameras, static analysis with CodeQL
- Bug bounty
 - Private programs
- Coordinated disclosure
 - Blackboard Inc.
 - Inspira AS
 - Internal systems at IDI and NTNU

Involvement in security research also improves security teaching in IDATT2503 Programvaresikkerhet og kryptografi.

Challenges with BSc-based pentests

- Students highly motivated but generally inexperienced
- Sometimes difficult to select willing third parties
- Attack surfaces are not thoroughly mapped - poor test coverage
- Semester time constraints, parallel activities, etc.

Want to pentest for your bachelor project?

Talk to me! Some ideas:

- Open-source/free software project
 - Source code, static, dynamic analysis
- Proprietary software/hardware product
 - e.g., Android/iOS app
 - Disassembly, decompilation, static, dynamic analysis
- Company
 - Web sites, cloud, network infrastructure, phishing
- Other ideas welcome

References

- Studenter avslørte alvorlig sikkerhetsfeil i utbredt IT-system. NRK.no. 2020. <https://www.nrk.no/kultur/studenter-avslorte-alvorlig-sikkerhetsfeil-i-biblioteks-15076878>
- Utrolig sikkerhetsfeil avdekket i nasjonalt IT-system. Digi.no. 2020. <https://www.digi.no/artikler/utrolig-sikkerhetsfeil-avdekket-i-nasjonalt-it-system/-491051?key=7YJN63D3>
- Reading silicon: How to reverse engineer integrated circuits <https://www.youtube.com/watch?v=aHx-XUA6f9g>
- A bug hunter's diary: A guided tour through the wilds of software security. Tobias Klein. 2011.